

AI Interaction Log

Author: Bryce **Date:** 2026-09-27 **AI Tool:** Claude (Cowork)

Task / Prompt

Review PR #4 (“Backend API: auth, profile, and resume endpoints”, branch `backend-api` → `main`) and check that it aligns with issue #2 (“[Task] Build the backend API for the Sprint 1 features”).

Context / Findings

- PR #4 declares `Closes #2`, builds on the database PR (#3), and includes its commit (“merge that first”). `MERGEABLE: true`. +2310/-0 across 17 files (12 new on top of the database branch): Express app, config, error class, middleware, auth/profile/resume routes, and an auth-flow test file.
- Stack/decisions: Express 5, JWT (stateless) via `jsonwebtoken`, `bcryptjs` hashing, `multer` disk-storage uploads. Matches issue #2’s open decisions.
- All 9 Sprint 1 endpoints present: `signup/login/logout/me`, `profile get/update`, `resume upload/list/delete`. Auth middleware (`requireAuth`) protects profile + resume routes. Consistent error responses (400/401/404/409) via a central error handler.
- Signup: email regex + 8-char min password + role whitelist; 409 on duplicate; creates the user and an empty profile in one transaction; never returns `password_hash`.
- Login returns a generic 401 (no user enumeration). Resume routes are scoped by `user_id` (no IDOR); delete removes the DB row and the file; upload validates MIME type (PDF/DOC/DOCX) and 5 MB size limit.
- Verification: exported `backend-api` to a scratch dir, `npm install`, `npm test` — all 6 tests pass (signup validation/dup, login, protected-route rejection, me, profile get/update, resume upload/list/delete).

AI Output / Actions

- Confirmed PR #4 aligns with issue #2: every Sprint 1 endpoint, task, and DoD item is covered, tests pass, endpoints documented in `backend/README.md`.
- Found one real bug: `UPLOAD_DIR` in `src/config.js` uses `new URL('../uploads', import.meta.url).pathname`, which leaves percent-encoding in the path. Reproduced: a project path containing a space (the team’s own iCloud path “Assignment 1”) resolves to `.../Assignment%201/backend/uploads`, so the running server would read/write a wrongly-named `Assignment%201` directory. Tests don’t catch it because they override `UPLOAD_DIR`. Fix: use `fileURLToPath()` instead of `.pathname`.
- Minor notes (non-blocking): stateless logout can’t truly invalidate a token before expiry (per-spec, acceptable); `JWT_SECRET` default is a dev placeholder (env-overridable, documented); IDs from the JWT `sub` are strings and rely on SQLite type affinity to match `INTEGER` columns (works, but explicit `Number()` would be clearer); `UPLOAD_DIR.pathname` is also not Windows-safe. Coordination: PR #4 already contains PR #3’s commits, so merge #3 first, then #4 (or #4 alone brings everything) — don’t merge them in a way that double-applies or drops the DB work.

Decision

Bryce: Flagged the UPLOAD_DIR bug as the one real blocker and passed the rest as non-blocking notes; the fix was handled in a follow-up (see fix-pr4-backend-api). Also noted the merge ordering with PR #3 so we didn't double-apply or drop the database work.

Reflection

Bryce: Actually running the branch and reproducing the bug with a spaced path made the review a lot more convincing than just reading the code. It also drove home why tests can miss things — the upload path bug was invisible because the tests override that value. Reviewing the whole auth flow taught me a fair bit about what a secure endpoint set looks like.